Comprehensive FERPA Software Testing Compliance Checklist

Document Purpose: Quality Assurance, Security, and Compliance Verification Test Suite for Software Handling Protected Student Education Records.

Regulatory Baseline: Family Educational Rights and Privacy Act (FERPA, 34 CFR Part 99), ISO/IEC 27001, ISO/IEC 27018, NIST SP 800-53 Rev. 5.

Source Synthesis: Microsoft Azure FERPA Implementation Guide, Microsoft Azure FERPA Compliance Framework Mapping, and Secure Privacy FERPA Software Guide.

Test Domain 1: Authentication, Authorization & Access Controls (34 CFR § 99.31)

Test ID	Test Objective	Test Procedure & Verification Steps	Expected Result / Acceptance Criteria
TC-AUTH-01	Multi-Factor Authentication (MFA) Enforcement	Attempt administrative, teacher, and counselor logins without MFA. Verify MFA challenge on external/BYOD network connections.	MFA is strictly mandated for all administrative roles and external logins; no unauthenticated access allowed.
TC-RBAC-02	Role-Based Access Control (RBAC) Least	Log in under different roles (General Teacher, Special Ed, Counselor, Principal, System Admin). Attempt	Access is strictly blocked with HTTP 403 Forbidden. System displays only

Test ID	Test Objective	Test Procedure & Verification Steps	Expected Result / Acceptance Criteria
	Privilege	to access records outside legitimate educational scope (e.g., Teacher accessing uninrolled students' psychological evals).	records where legitimate educational interest exists.
TC-RBAC-03	Horizontal Privilege Escalation (IDOR Prevention)	Modify API request parameters (e.g., GET /api/students/10452/grades replaced with 10453) using an authenticated session not authorized for student 10453.	Backend enforces server-side tenant and user object-level ownership checks; request rejected with 403/404.
TC-SESS-04	Session Inactivity Timeout & Termination	Authenticate into the application, leave the browser idle for 15 minutes. Attempt an action on a protected record.	Session terminates automatically after 15 minutes; sensitive data cleared from DOM/cache; redirect to re-login.
TC-TENANT-05	Multi-Tenant Logical Isolation	Execute cross-district queries using authorized credentials from School District A against School District B data stores.	Zero data leakage; queries strictly scoped by tenant partition key/filter.

Test Domain 2: Data Protection, Cryptography & Secure Transmission

---

Test ID	Test Objective	Test Procedure & Verification Steps	Expected Result / Acceptance Criteria
TC-CRYP-01	Data-in-Transit Encryption (TLS 1.2+)	Inspect TLS configurations of all public web interfaces and microservice APIs using SSL Labs / test tools. Attempt HTTP or TLS 1.0/1.1 handshakes.	HTTP automatically redirects to HTTPS. TLS 1.0 and 1.1 handshakes are rejected. TLS 1.2/1.3 with Perfect Forward Secrecy enforced.
TC-CRYP-02	Data-at-Rest Encryption	Verify cryptographic settings across database tables, object storage (S3/Azure Blob), transaction logs, and snapshot backups.	All protected student data encrypted at rest using AES-256 with keys managed in dedicated HSM/Key Vault.
TC-CRYP-03	Indirect Identifier & PII Sanitization in Logs	Trigger application errors, authentication events, and search queries. Inspect server, console, and crash logs.	No student PII, passwords, session tokens, or SSNs written to unencrypted application logs or diagnostic outputs.
TC-KMS-04	Cryptographic Key Rotation & Segregation	Verify separation of duties between key management administrators and application developers. Test scheduled key rotation procedures.	Keys rotated without service disruption; no plaintext keys hardcoded in repositories or configuration files.

Test Domain 3: Audit Logging & Non-Repudiation (34 CFR § 99.32)

Test ID	Test Objective	Test Procedure & Verification Steps	Expected Result / Acceptance Criteria
TC-LOG-01	Comprehensive Record Access Audit Logging	Perform CRUD operations, report views, batch exports, and API fetches on student records. Verify generated log entries.	Log entry created containing: UTC Timestamp, Actor ID, Actor Role, Student ID, Record Entity, Action Type, Source IP, and Educational Justification.
TC-LOG-02	Log Immutability & Anti-Tampering	Attempt to update, truncate, or delete audit log entries using database administrator or privileged application credentials.	Audit logs are write-once, append-only (WORM storage). Modification or deletion operations fail completely.
TC-LOG-03	Parent/Eligible Student Access Log Inspection	Submit a query requesting the record of disclosures for a specific student pursuant to 34 CFR § 99.32.	System generates an audit summary showing legitimate inspection history excluding internal school officials without disclosure.
TC-LO	Suspicious	Simulate off-hours bulk export (e.g.,	Automated security alert

Test ID	Test Objective	Test Procedure & Verification Steps	Expected Result / Acceptance Criteria
G-04	Activity & Anomaly Alerting	downloading 1,000+ student records at 2:00 AM) or impossible travel logins.	triggered within 60 seconds; administrative notification sent to CISO/Privacy Officer.

Test Domain 4: Data Rights, Consent & DSAR Lifecycle (34 CFR §§ 99.10, 99.20, 99.30)

Test ID	Test Objective	Test Procedure & Verification Steps	Expected Result / Acceptance Criteria
TC-DSAR-01	Parent Access Request (45-Day SLA Fulfillment)	Submit a Data Subject Access Request for a student. Verify aggregated search across all integrated subsystems (SIS, LMS, counseling).	Complete record compiled in under 45 days. SLA countdown dashboard triggers automated escalation alerts at Day 15, 30, and 40.
TC-DSAR-02	Peer Redaction in Composite Records	Request access to records containing multiple students (e.g., incident report or group exam	System redacts or omits all other students' PII so the requesting parent sees

Test ID	Test Objective	Test Procedure & Verification Steps	Expected Result / Acceptance Criteria
		roster). Verify output document.	only their child's information.
TC-AMND-03	Record Amendment & Contested Statement Attachment	Submit record amendment request (34 CFR § 99.20). Simulate rejection of amendment and attach parent contested statement.	Contested statement is permanently linked to the disputed record; automatically bundled whenever record is retrieved or exported.
TC-CONS-04	Directory Information Opt-Out Enforcement	Set student flag directory_opt_out = true (34 CFR § 99.37). Query public directory, honor roll export, and external roster APIs.	Student is excluded from public directories and external rosters; opt-out status syncs in real time across all application modules.
TC-CONS-05	Prior Written Consent Gate for Third Parties	Attempt to export or stream student data to a commercial third party not designated as a School Official.	System checks for valid, active written consent record. Transmission blocked if consent is missing, expired, or revoked.

Test Domain 5: Data Minimization, Lifecycle & Re-disclosure Restrictions

---

Test ID	Test Objective	Test Procedure & Verification Steps	Expected Result / Acceptance Criteria
TC-LIFE-01	Automated Retention & Secure Deletion Purge	Set student graduation/departure date past retention policy threshold (e.g., 5 years). Run data retention lifecycle job.	Non-permanent records permanently purged or de-identified; permanent transcripts preserved per statutory state schedules.
TC-REDIS-02	Secondary Use & Advertising Tracker Prohibition	Audit network calls, client-side JavaScript, and SDKs. Inspect data sharing pipelines for marketing telemetry or tracking pixels.	Zero third-party advertising scripts, Facebook/Google tracking pixels, or commercial telemetry detected.
TC-EMRG-03	Health & Safety Break-Glass Workflow (34 CFR § 99.36)	Activate emergency break-glass access to view medical/emergency contact records without prior consent.	User must record specific, articulable emergency justification. Incident logged with elevated priority; alert sent to compliance officer.